المرفق رقم /١/: النتائج المنبثقة عن المهمة والإجراءات التصحيحية المقترحة:

١) التقييم الشامل لنطاق المهمة من ناحية التزام المصرف ببعض القوانين والقرارات النافذة:

استناداً إلى الدراسة التفصيلية لنظم تقانة المعلومات المستثمرة لدى بنك بيبلوس سورية والإجراءات والسياسات والعلاقة بين المصرف والشريك الاستراتيجي، ومن خلال دراسة القوانين والقرارات والضوابط النافذة، نورد تقييم القرارات والضوابط التالية من الجانب التقني فقط والمخاطر المتعلقة به حصراً:

أ) القرار رقم ٣٩١/م ن/ب٤ لعام ٢٠٠٨- التعليمات الخاصة بمتطلبات تأمين استمرارية عمل المصرف:

١. عدم جهوزية الموقع البديل ومواجهة الكوارث في طرطوس حتى تاريخ المهمة الميدانية في العام ٢٠١٨.
٢. يتواجد الموقع البديل لدى الشريك الاستراتيجي، مع عدم وجود اتفاقية معتمدة أو إطار قانوني. تؤطر العلاقة والمسؤوليات[١].
٣. تتواجد معظم مكونات البنية التحتية التشغيلية خارج سورية، مع عدم وجود اتفاقية معتمدة أو إطار قانوني. تؤطر العلاقة والمسؤوليات
٤. يقوم المصرف بالعمل على إنشاء موقع بديل في فرع للمصرف في طرطوس خلال العام ٢٠١٩.
٥. لا يوجد سجل لدى المصرف للتحقق من الالتزام بإعلام مفوضية الحكومة لدى المصارف عن أي من المخاطر أو الأعطال التي قد تحصل فور حصولها.
٦. تقتصر إجراءات استمرارية العمل على النظام المصرفي الأساسي فقط وهي معتمدة على مستوى مجموعة بنك بيبلوس في كافة دول العالم.
٧. عدم اعتماد الوثائق المتعلقة بإجراءات العمل الخاصة بالاستمرارية من مجلس إدارة بنك بيبلوس سورية.
٨. لا يوجد خطة شاملة لاستمرارية الأعمال تتضمن إجراءات شاملة وفعالة لمواجهة مخاطر الحالات الطارئة.

ب) القرار رقم ٣٩٠/م ن/ب٤ لعام ٢٠٠٨ - التعليمات الخاصة المتعلقة بمسؤولية مجلس الإدارة في إدارة المخاطر: لا يوجد التزام فعلي وكامل بمسؤولية مجلس الإدارة في إدارة المخاطر ذات الصلة بموضوع المهمة حيث يتم الاعتماد على الشريك الاستراتيجي بشكل أساسي بذلك، فعلى سبيل المثال لا الحصر:

[١] بناء على التصريح الشفهي من السيد نائب المدير العام-

١. لا توفر الإدارة العليا كافة البنى اللازمة لإدارة ومتابعة المخاطر التي يتعرض لها المصرف وبشكل مستمر
٢. لا تقوم الإدارة العليا بوضع السياسات والإجراءات لمواجهة كافة أنواع المخاطر التي يتعرض لها المصرف
٣. لا تتقيد الإدارة العليا بتنفيذ استراتيجية المخاطر المعتمدة من قبل مجلس الإدارة وبما يتفق وسقوف المخاطر المحددة.

ج) المادة الأولى من التعليمات الخاصة بالمخاطر التشغيلية المرفقة بالقرار رقم ١٠٦/م ن/ب٤ لعام ٢٠٠٥ لجهة:

١. عدم دراية المجلس على النحو المطلوب بالمخاطر التشغيلية الهامة التي تواجه المصرف باعتبارها مخاطر يجب الاهتمام بها والاحتياط لها وإنما يعتمد على الشريك الاستراتيجي لديه بهذا الدور.
٢. عدم وجود نظام مصادق لإدارة المخاطر التشغيلية.

د) القرار رقم ١٢٠/م ن/ب٤ لعام ٢٠٠٥ الخاص بأنظمة الضبط الداخلي:

١. **المادة (١) من التعليمات الخاصة بأنظمة الضبط الداخلي لدى المصارف المرفقة بالقرار المذكور لجهة** عدم وجود أعضاء ضمن مجلس الإدارة يتمتعون بالخبرة والمعرفة بنشاط المصرف التقني وبالمخاطر التي يواجهها بهذا الجانب، وبكل ما يحدث في دوائره حيث يعتمد بذلك على الشريك الاستراتيجي، إضافة لعدم كفاية الكوادر التقنية حيث يقتصر عدد الكادر التقني -خلال المرحلة الميدانية للمهمة- في المصرف شخصين فقط.
٢. **المادة (٦) من التعليمات الخاصة بأنظمة الضبط الداخلي لدى المصارف المرفقة بالقرار المذكور لجهة** عدم وجود خطط شاملة أو بديلة في حال حصول أية مشاكل في النظام المعلوماتي، وإنما يعتمد بشكل رئيسي على الشريك الاستراتيجي، لا سيما فيما يتعلق بالنظام المصرفي الأساسي.

هـ) القرار رقم ١٢١/م ن/ب٤ لعام ٢٠٠٥ التعليمات الخاصة بتعزيز أصول إدارة المؤسسات المصرفية لجهة عدم قيام مجلس الإدارة بوضع الأهداف الاستراتيجية –فيما يتعلق بالجانب التقني حصراً- وتحديد سياسة ومبادئ العمل، حيث يعتمد بهذا الخصوص على الشريك الاستراتيجي، بدون توفر منهجية معيارية شاملة خاصة بالمصرف.

و) القرار رقم ١١٥٠/م ن/ب١لعام ٢٠١٤ تعليمات بخصوص المراقبة التلفزيونية للمصارف العاملة لجهة:

١. لا يوجد إجراءات معتمدة بخصوص عملية المراقبة التلفزيونية للمصرف.
٢. البند رابعاً-الجدول /٨/ من الضوابط والإجراءات الخاصة باستخدام المراقبة التلفزيونية في المصارف لجهة عدم وجود عقد صيانة للأعطال ذات الصلة، أو كادر متخصص لدى المصرف، حيث تتم الصيانة بالفاتورة .Case by Case

ز) **القرار ٣٣١/م ن/ب٤ لعام ٢٠٠٧ والقرار ١٣٧٦/م ن/ب٤ لعام ٢٠١٦ و القرار رقم ٤٥/ م ن لعام ٢٠١٨ الخاصة بتحديد توقيت عمل المصارف،** لجهة عدم كفاية إعدادات نظم تقانة المعلومات بما يتوافق مع متطلبات القرارات المذكورة. حيث أن تبين أن إعدادات النظام لا تضبط توقيت التشغيل حسب القرارات، مثلاً يمكن العمل على النظام في أيام العطل وخارج أوقات الدوام.

ح) **المادة /١/ من القرار رقم ٧٩٤٧/م.و لعام ٢٠١٢ المتضمن ضوابط الترخيص لشركات الدفع الإلكتروني لجهة:**

١. تعاقد المصرف مع شركة غير مرخصة من قبل مصرف سورية المركزي وهي شركة CSC لبنان/شركة خدمات بطاقات الائتمان/، حيث أنها غير مرخصة للعمل في سورية وذلك منذ عام ٢٠٠٧ ولم تتم الموافقة من قبل مصرف سورية المركزي على تعاقد المصرف معها.
٢. يعتمد المصرف على طرف ثالث دون وجود إطار تنظيمي وقانوني ينسجم مع القرارات النافذة، فمثلاً لا يوجد بالحد الأدنى اتفاقية دعم فني وتعاون تشغيلي بين المصرف والشريك الاستراتيجي ولا يوجد اتفاقية استضافة وغيرها.

ط) **المادة /٣٥/ من قرار لجنة إدارة هيئة مكافحة غسل الأموال وتمويل الإرهاب رقم (١٥) لعام ٢٠١٥--ولا سيما البند (٢) منها-، المتضمن نظام مراقبة العمليات المصرفية والمالية بغرض مكافحة غسل الأموال وتمويل الإرهاب، والذي تم إنهاء العمل به بالقرار رقم (١٩) لعام ٢٠١٩،** لجهة عدم الالتزام بحفظ بيانات العملاء على النظم المعلوماتية باللغة العربية، حيث أن كافة البيانات باللغة الإنكليزية.

ي) **عدم الالتزام بالمعايير والممارسات العالمية في مجال التدقيق المعلوماتي مثل ISO, COBIT الأمر الذي يعرض المصرف إلى مخاطر تشغيلية عالية لجهة:**

المحور الأول: دور الإدارة في الإشراف على نظم تقانة المعلومات وذلك في الجوانب التالية:

١. معظم النظم المعلوماتية من مصادر خارجية ولا يوجد إطار قانوني ينظمها.
٢. لا يوجد خطة استراتيجية عامة أو خاصة بإدارة تقانة المعلومات.
٣. لا يوجد تقارير تدقيق/متابعة داخلية من بنك بيبلوس-سورية لضمان معالجة انحرافات الالتزام بتطبيق معايير وإجراءات أمن نظم تقانة المعلومات ومعالجتها في الوقت المناسب.
٤. لا يوجد تقارير تدقيق -داخلية أو خارجية- شاملة وفعالة للموظفين لتقليل مخاطر نظم تقانة المعلومات الناجمة عن فشل النظم أو التخريب الداخلي أو الاحتيال.

المحور الثاني: إدارة مخاطر نظم تقانة المعلومات من الجوانب التالية:

١. يوجد نظم للحماية والأمن الفيزيائي فقط وإجراءات مكتوبة غير معتمدة.

٢. يعتمد بنك بيبلوس سورية على الإدارة التقنية من بنك بيبلوس لبنان، حيث يعمل بيبلوس سورية على بنية تقنية فرعية من البنية التقنية الرئيسية لبنك بيبلوس لبنان.
٣. تم الاطلاع على خطط تدقيق للأعوام ٢٠١٨،٢٠١٧،٢٠١٦ ولم يتبين وجود تقارير تدقيق داخلي معدة من قبل الإدارة المعنية في المصرف، كما أن تقارير التدقيق المعدة من الشريك الاستراتيجي لا تتضمن مراجعة لنتائج تقارير سابقة.

المحور الثالث: إدارة مخاطر نظم تقانة المعلومات من مصادر خارجية من الجوانب التالية:

١. لا تمكّن العلاقة مع مزود الخدمة الجهات التنظيمية والرقابية من تقييم مخاطر تقانة المعلومات والتي تشمل فحص ومراقبة واختبار مسؤوليات وأدوار والتزامات ووظائف ونظم ووسائل مزود الخدمة، على سبيل المثال: لا يمكن التدقيق على نظام إصدار وإدارة البطاقات نظراً لعلاقة المصرف مع CSC لبنان غير المرخصة في سورية.
٢. لا تضمن الاتفاقات التعاقدية مع مزود الخدمة صلاحية الجهات الرقابية والتنظيمية لتقييمه، حيث لا يوجد إطار قانوني ناظم لذلك.
٣. لا يلتزم مزود الخدمة باتخاذ كل ما يلزم للمحافظة على مستوى عالي في سياساته الأمنية وإجراءاته وضوابطه لحماية سرية وأمن معلومات المصرف الحساسة أو السرية، مثل بيانات العملاء والملفات الإلكترونية والسجلات والبرامج ومصادرها الترميزية (Source Codes)، فعلى سبيل المثال: زوّد بنك بيبلوس- سورية الفريق الرقابي بملف يتضمن قائمة بالمستخدمين على نظام المصرف الأساسي في سورية ولبنان.
٤. بنك بيبلوس لبنان مسؤول عن كافة خطط الطوارئ المتعلقة بنظم تقانة المعلومات في بنك بيبلوس- سورية.

المحور الرابع: الاستحواذ على نظم تقانة المعلومات وتطويرها من الجوانب التالية:

١. يعتمد بنك بيبلوس - سورية على بنك بيبلوس لبنان في كافة نظم تقانة المعلومات المستثمرة لديه، حيث كما ذكر سابقاً بأن معظم النظم المعلوماتية من مصادر خارجية ولا يوجد إطار قانوني ينظمها.
٢. لا يوجد تحديد واضح للمتطلبات الأمنية المتعلقة بضوابط الدخول إلى النظام والمصادقة وتفويض العمليات وسلامة البيانات وسجل عمليات النظام ومراجعة الحسابات وتتبع الأحداث الأمنية ومعالجة الاستثناءات في المرحلة الأولى من تطوير (أو الاستحواذ) النظام، حيث يوجد سياسة لأمن معلومات نظام المصرف الأساسي T٢٤ في الحالات الخاصة التي يحدث فيها مشاكل لدى بنك بيبلوس - سورية بالعمل مع بنك بيبلوس لبنان.
٣. لا يوجد منهجية اختبار داخلي للاختراق سواء للشبكة الداخلية أو الخارجية.

المحور الخامس: إدارة خدمات تقانة المعلومات من الجوانب التالية:

يوجد ضوابط ومنهجية لإدارة التغيير من قبل المورد الخارجي وبنك بيبلوس لبنان، ولكن لا يوجد إطار قانوني ينظم العلاقة فيما بينهم وبنك بيبلوس - سورية، ودور بنك بيبلوس - سورية أقل من ثانوي في هذا الإطار.

المحور السادس: موثوقية النظم واستمراريتها واستعادتها من الجوانب التالية:

لا يشارك المصرف في تصميم وتنفيذ حالات الاختبار الشاملة للمستخدمين للتحقق من أن النظم التي تم استعادتها تعمل بشكل صحيح، حيث يوجد خطة للاستعادة لمجموعة بنك بيبلوس بشكل عام وليست خاصة ببنك بيبلوس- سورية فقط.

المحور السابع: البنية التحتية التشغيلية لإدارة أمن المعلومات من الجوانب التالية:

١. يوجد اطلاع كامل وتحكم لبنك بيبلوس لبنان على نظم معلومات وبيانات بنك بيبلوس - سورية –كما ذكر أعلاه-، ولا يوجد إطار قانوني ناظم لذلك.
٢. يوجد اطلاع وتحكم كامل لشركة CSC لبنان (وهي غير المرخصة في سورية كما ذكر أعلاه).
٣. لم يطّلع الفريق الرقابي على إجراءات أو سياسات مكتوبة بخصوص المذكور في الملاحظتين السابقتين.
٤. معظم العقود –ذات الصلة بالموضوع المذكور- موقعة في السنوات السابقة من غير تجديد أو تعديل.

المحور الثامن: ضوابط وإجراءات حماية مراكز البيانات من الجوانب التالية:

١. لا يحقق مركز البيانات الرئيسي الكائن في مقر الإدارة العامة في دمشق- الشعلان، أدنى المواصفات المعيارية والممارسات المهنية المماثلة، وحسب الواقع التقني لنظم معلومات المصرف فإن هذا المقر يمكن اعتباره إلى حدٍ ما مركز بيانات احتياطي وليس رئيسي.
٢. لا يوجد سياسة أو إجراءات أمنية تشمل هذا النطاق.

المحور التاسع: التحكم بالدخول من الجوانب التالية:

١. يوجد نظام للتحكم بالدخول ومراقبة الدوام، ولا توجد منهجية وإجراءات معتمدة
٢. لا يُمنح وصول للمستخدم إلى نظم وشبكات تقانة المعلومات على أساس الحاجة إلى الاستخدام وخلال الفترة التي يكون فيها الوصول مطلوباً، حيث أن التحكم كامل لبنك بيبلوس لبنان على نظم معلومات بنك بيبلوس- سورية، ولا يوجد إطار قانوني ناظم لذلك.

المحور العاشر: الخدمات المصرفية الإلكترونية من الجوانب التالية:

١. لا يوجد التزام ببعض قرارات وضوابط رئاسة مجلس الوزراء ومجلس النقد والتسليف، مثلاً القرارات ذوات الأرقام: ٧٩٤٧/م.و لعام ٢٠١٢، ١١٨٠/م.ن لعام ٢٠١٤، و٦٤/م.ن لعام ٢٠١٧ و ٩٤/م.ن لعام ٢٠١٨

٢. لا تتم المصادقة الثنائية عند تسجيل الدخول للنظم المصرفية عبر الإنترنت، وإنما فقط من خلال User \password.

٣. يقدم المصرف خدمات إلكترونية من خلال بطاقات السحب من الصرافات الآلية والتي يتم تشغيلها من خلال محولة مستضافة في لبنان من قبل شركة CSC لبنان وهي غير مرخصة في سورية، وكما ذكر أعلاه لا يوجد إطار قانوني ناظم للعلاقة مع شركة CSC متوافق مع ضوابط مصرف سورية المركزي ذات الصلة.

٤. يقدم المصرف خدمات إلكترونية eBanking من خلال منظومة لدى بنك بيبلوس لبنان ولا يوجد إطار قانوني ناظم للعلاقة معه.

٥. يعتمد التشفير وأمن المعلومات على المنتجات والعلاقة مع موردیها، ولكن لا يوجد إطار قانوني ينظم العلاقة مع الموردين الخارجيين لهذه النظم.

المحور الحادي عشر: أمن وحماية بطاقات الدفع الإلكتروني (Prepaid Cards ATM, Credit, Debit and) من الجوانب التالية:

نظام إصدار وإدارة وتشغيل البطاقات مورد ومستضاف لدى طرف خارجي في لبنان، ولا يوجد إطار قانوني ينظم العلاقة وفق الضوابط والقرارات النافذة.

المحور الثاني عشر: تدقيق تقانة المعلومات من الجوانب التالية:

يتم تنفيذ خطط تدقيق سنوية من قبل الشريك الاستراتيجي وجهات خارجية ولكنها غير شاملة لكافة جوانب العمل التقني في المصرف.

المحور الثالث عشر: اختبار أمن النظم ومراجعة الكود المصدري من الجوانب التالية:

يوجد تحكم كامل لبنك بيبلوس لبنان على نظم معلومات بنك بيبلوس - سورية، ولا يوجد إطار قانوني ناظم لذلك.

المحور الرابع عشر: استيعابية نظم التخزين من الجوانب التالية:

لا يوجد منهجية معتمدة بهذا الخصوص، ويعتمد المصرف بشكل كامل على بنك بيبلوس لبنان ولا يوجد إطار قانوني ناظم لذلك.

المحور الخامس عشر: التشفير من الجوانب التالية:

لم يتم تزويد الفريق الرقابي بوثائق بهذا الخصوص في إطار متطلبات وضوابط أمن وحماية المعلومات والسرية، وتبين بالتدقيق للفريق الرقابي عدم وجود منهجية معيارية موحدة بخصوص التشفير لدى المصرف، ويعتمد على المنتجات وموردیها مع الشريك الاستراتيجي، وعليه لا يوجد دور لبنك بيبلوس - سورية بهذا الخصوص بشكل كامل.

المحور السادس عشر: الحماية من حجب الخدمة الموزعة من الجوانب التالية:

١. لا يوجد إطار قانوني مع بنك بيبلوس لبنان يضمن استمرارية خدمات بنك بيبلوس - سورية
٢. يستخدم بنك بيبلوس- سورية خطوط اتصالات من مزودات خدمة محلية ودولية (لبنان) ولا يوجد إطار قانوني ينظم العلاقة مع الطرف الخارجي (الدولي).
٣. يتعاقد المصرف مع شركة غير مرخصة في سورية ومنظومتها خارج سورية (CSC-لبنان) من أجل خدمات البطاقات والصرافات الآلية.
٤. لا يوجد عضوية مباشرة لبنك بيبلوس سورية في شبكة سويفت للتحويلات المالية العالمية، ويستخدم المصرف ترخيص الشريك الاستراتيجي وبشكل محدود ومقيد.

المحور السابع عشر: الإجراءات الأمنية للنظم عبر الانترنت (نظم الخدمات الإلكترونية) من الجوانب التالية:

لا يوجد إجراءات معتمدة بهذا الخصوص، ويعتمد المصرف على بنك بيبلوس لبنان في كافة الجوانب المرتبطة بنظم معلومات بنك بيبلوس - سورية، وكما ذكر أعلاه لا يوجد إطار قانوني ناظم لذلك.

المحور الثامن عشر: توعية وحماية العملاء من الجوانب التالية:

لدى المصرف خدمات انترنت EBanking من خلال منظومة الشريك الاستراتيجي في لبنان، ويعتمد عليه في كافة الجوانب المرتبطة بنظم تقانة معلوماته وخدماته التقنية والضوابط والإجراءات ذات الصلة، ولم تتوفر للفريق الرقابي معلومات كافية بهذا السياق، حيث كما ذكر أعلاه لا يوجد إطار قانوني ناظم لذلك.

٢) يستثمر بنك بيبلوس سورية حالياً بنية تقنية مكونة من نظم تقنية متعددة ومختلفة، وتبين بالاطلاع على هذه البنية ومكوناتها وضوابطها الملاحظات التالية:

أ. تقادم معظم إصدارات نظم المعلومات المستثمرة وحاجتها للتحديث تحديث.
ب. استحواذ مورد خارجي على معظم النظم التقنية لدى المصرف (أغلبها من بنك بيبلوس لبنان)
ج. استضافة معظم نظم المعلومات خارج سورية لدى بنك بيبلوس لبنان وهي (T٢٤ Globus النظام المصرفي، الحوالات الخارجية SWIFT، CRM System/ Siebel، إدارة بطاقات الائتمان Open٢ Switch ، Online Banking، Byblos Retail Information System، Fico Tonbeller

Compliance Solutions AML، WebSite، Inventory Application، (Triton) Websence، (Purple\ intranet application and document management system) ونظام إدارة بطاقات الائتمان CSC لدى شركة بطاقات الائتمان CSC/ لبنان.

د. عدم وجود سياسات وإجراءات ونظم عمليات لعدد من النظم، وعدم اعتماد السياسات الموجودة للنظم الأخرى وعدم مراجعتها وتحديثها دورياً.

هـ. تتم إدارة معظم النظم التقنية من قبل بنك بيبلوس لبنان، ولا يوجد كادر مؤهل أو بديل في بنك بيبلوس سورية يمكنه القيام بهذا الدور، حيث يقتصر الكادر البشري لدى تقانة المعلومات في بنك بيبلوس سورية على شخصين.

و. عدم وجود معظم عقود الدعم الفني والصيانة واتفاقيات على مستوى الخدمة لنظم المعلومات وفي حال وجودها فهي غير سارية (وغير نافذة)، كما لا توجد إجراءات وسياسات معتمدة لدى المصرف للتعامل مع الموردين الخارجين.

ز. لا يوجد تخطيط أو اختبارات تتعلق بالسعات الاستيعابية للتجهيزات، ولا يوجد قطع تبديلية.

ح. لا يحقق مركز البيانات في دمشق أدنى المواصفات المعيارية والممارسات المهنية المماثلة، وبحسب الواقع التقني لنظم معلومات المصرف فإن هذا المقر يمكن اعتباره إلى حدٍ ما مركز بيانات احتياطي وليس رئيسي.

ط. تواجد مركز البيانات الاحتياطي في لبنان/ بيروت لدى الشريك الاستراتيجي، وحسب الواقع التقني لنظم معلومات المصرف فإن هذا المقر هو مركز البيانات الرئيسي لبنك بيبلوس – سورية.

٣) دراسة الصلاحيات والمستخدمين على بعض النظم المعلوماتية المستثمرة لدى المصرف:

أولا- النظام المصرفي الأساسي Core Banking System- المستخدمين متعددي ملفات الصلاحيات- المستخدمين بصلاحيات عالية المستوى- نظام إدارة تواقيع ومعلومات العملاء وتفويضاتهم- نظام إدارة بطاقات الائتمان Open٢ Switch- نظام إدارة المعلومات Purple\ intranet application and document management system،

تبين وجود قصور ملحوظ في الالتزام بالضوابط ذات الصلة الصادرة عن مجلس النقد والتسليف والممارسات العالمية المثلى، الأمر الذي يحمل المصرف مخاطر مرتفعة متنوعة وقد تؤدي إلى آثار جسيمة على المصرف نفسه وعلى القطاع المصرفي ككل، وقصور في سياسات المصرف الداخلية وإجراءات الضبط الداخلي ذات الصلة، إضافة إلى تعرضه لمخاطر عدم الالتزام بقرارات مجلس النقد والتسليف وفق ما ذكر أعلاه، الأمر الذي يستدعي قيام المصرف بالآتي خلال فترة لا تتجاوز (ثلاثة أشهر) من تاريخ الكتاب:

أ) نقل بيئة عمل النظام المصرفي الأساسي T٢٤ إلى مركز البيانات الرئيسي في بنك بيبلوس- سورية بدمشق مع رخصة استخدام لبنك بيبلوس - سورية إما من المورد أو من الشريك الاستراتيجي، واستخدام اللغة العربية في كافة بيانات العمل.

ب) اعتماد خطة زمنية للانتقال وحذف بيانات العمل والعملاء والعمليات بشكل نهائي من بيئة عمل الشريك الاستراتيجي بشكل كامل ونهائي وغير قابل للاسترداد وبما يتفق مع أحكام السرية المصرفية والقوانين السورية النافذة.

ج) إعادة هندسة إجراءات العمل على النظام بما ينسجم مع السياسات والإجراءات المعتمدة من مجلس إدارة بنك بيبلوس - سورية، مع مراعاة توزع الصلاحيات والبدائل وفق مبدأ الرقابة المتعددة (٤-EYE) لكافة أنواع العمليات المالية والمحاسبية والإدارية وفق التعميم رقم ١/٠/٦٨١ لعام ٢٠١٤

د) منح الصلاحيات على النظام المصرفي وفق آلية وإجراءات معيارية موثقة ومعتمدة من مجلس إدارة بنك بيبلوس - سورية

هـ) تجميد حسابات المستخدمين من غير العاملين في بنك بيبلوس - سورية

و) عدم منح سماحيات الحذف[٢] لأي مستخدم على النظام

ز) حصر سماحيات النقل والنسخ والطباعة حسب الحاجة والضرورة وبموافقة من المستوى الإداري المناسب

ح) عدم السماح للمستخدمين بالعمل على النظام عن بعد بغض النظر عن الدور الوظيفي

ط) عدم السماح بالعمل على النظام في أيام العطل بغض النظر عن الدور الوظيفي.

ي) تطبيق إعدادات على النظام بجدول أيام العمل والعطل (روزنامة) وتحديثها سنوياً.

ك) تطبيق إعدادات على النظام بعدد ساعات العمل حسب القرارات الناظمة من مصرف سورية المركزي

ل) تطبيق هذه المقترحات على كافة مستخدمي النظام المصرفي الأساسي

م) ضبط أسماء المستخدمين بما يتطابق مع كافة النظم التقنية المستثمرة في المصرف

ن) تحديث النظام المصرفي الأساسي وبيئة التشغيل بشكل دوري حسب مقترحات الموردين

س) وضع إجراءات تشغيل ودعم فني وصيانة ونسخ احتياطية معيارية

ع) توفير بيئة تجريبية منفصلة عن بيئة الاستثمار من أجل اختبار كافة التغييرات قبل تطبيقها على النظام المصرفي الأساسي.

[٢] سماحية الحذف تعطى للمستخدم من أجل حذف بيانات عميل أو عملية أو ما شابه من بيانات على النظام/ وذلك غير مقبول في النظم المصرفية/ يمكن التعديل مع إبقاء الأصل.

ثانياً- نظام التحويلات المالية الخارجية / سويفت:

تبين وجود قصور ملحوظ في الالتزام بالضوابط ذات الصلة الصادرة عن مجلس النقد والتسليف والممارسات العالمية المثلى، قد تحمل المصرف مخاطر مرتفعة متنوعة وتؤدي إلى آثار جسيمة على المصرف نفسه وعلى القطاع المصرفي ككل، الأمر الذي يستدعي قيام المصرف بالآتي خلال فترة لا تتجاوز (ثلاثة أشهر) من تاريخ الكتاب:

أ) الاشتراك بعضوية مباشرة للمصرف لدى سويفت ورخصة استخدام لنظام سويفت مستقلة[٣].

ب) تركيب بيئة عمل مستقلة لنظام سويفت في مركز البيانات الرئيسي في بنك بيبلوس سورية بدمشق أو في مركز بيانات الشريك الاستراتيجي

ج) اعتماد خطة للانتقال وحذف البيانات بشكل نهائي وغير قابل للاسترداد من بيئة عمل الشريك الاستراتيجي وبما يتفق مع أحكام السرية المصرفية والقوانين السورية النافذة.

د) إعادة هندسة إجراءات العمل على النظام بما ينسجم مع السياسات والإجراءات المعتمدة من مجلس إدارة بنك بيبلوس سورية، مع مراعاة توزع الصلاحيات والبدائل وفق مبدأ الرقابة المزدوجة (٤-EYE) لكافة أنواع العمليات المالية والمحاسبية والإدارية وفق التعميم رقم ١/٠/٦٨١ لعام ٢٠١٤

هـ) منح الصلاحيات على النظام وفق آلية وإجراءات معيارية موثقة ومعتمدة من مجلس إدارة بنك بيبلوس سورية.

و) تجميد حسابات المستخدمين من غير العاملين في بنك بيبلوس سورية.

ز) عدم السماح بالعمل على النظام في أيام العطل بغض النظر عن الدور الوظيفي.

ح) تطبيق إعدادات على النظام بجدول أيام العمل والعطل (روزنامة) وتحديثها سنوياً.

ط) تطبيق إعدادات على النظام بعدد ساعات العمل حسب القرارات الناظمة من مصرف سورية المركزي

ي) تطبيق هذه المقترحات على كافة المستخدمين

ك) ضبط أسماء المستخدمين بما يتطابق مع كافة النظم التقنية المستثمرة في المصرف

ل) وضع إجراءات تشغيل ودعم فني وصيانة ونسخ احتياطي معيارية.

ثالثاً- نظام إدارة قواعد البيانات jBase:

حسب ما ورد من بنك بيبلوس[٤] - سورية فإن: *"كافة المستخدمين من بنك بيبلوس سورية لديهم صلاحيات متشابهة في نظام قواعد البيانات jBase على مخدم النظام المصرفي الأساسي T٢٤ الخاص*

[٣] لا يوجد ما يمنع خاصةً وأن ذلك مطبق في عدد من المصارف السورية العامة ومصرف سورية المركزي.

[٤] ملف إكسل باسم "jBase Access Rights ٢-٢"

بسورية لأنهم يعملون على نفس الملفات، ويوجد مستخدمين بصلاحيات عالية غير متوفرة للمستخدمين في بنك بيبلوس - سورية" ، وهم:

جدول رقم (١):دراسة كفاية نظام إدارة قواعد البيانات

Jbase ٤.١.٥.٢٩		
اسم الشخص	**اسم المستخدم**	**ملاحظات**
Machhour Salem	MSALEM	▪ مستخدمين من خارج بنك بيبلوس سورية لديهم صلاحيات عالية المستوى Super User لإدارة نظام قواعد البيانات JBase ، ولا يوجد مستخدم بصلاحيات مماثلة في بنك بيبلوس سورية ▪ لا يوجد آلية معيارية أو سياسات وإجراءات للعمل معتمدة ▪ عدم استخدام اللغة العربية
Hisham Hasaniyyah	HHASANIA	
Georges Noujeim	GNOUJEIM	
Ravia Koussa	RKOUSSA	
Elias Tanios	ETANIOS	
Johnny Eid	JOEID	
Alexandre Abed	AABED	

الأمر الذي يعتبر قصور في الالتزام بالضوابط ذات الصلة الصادرة عن مجلس النقد والتسليف والممارسات العالمية المثلى، ويحمّل المصرف مخاطر مرتفعة متنوعة قد تؤدي إلى آثار جسيمة على المصرف، الأمر الذي يستدعي قيام المصرف بالآتي خلال فترة لا تتجاوز (ثلاثة أشهر) من تاريخ الكتاب مع الأخذ بالاعتبار ما ورد أعلاه ضمن فقرة النظام المصرفي الأساسي، حيث هذا النظام يتكامل وظيفياً وتقنياً مع النظام المصرفي الأساسي-:

أ) نقل نظام قواعد البيانات إلى مركز البيانات الرئيسي في بنك بيبلوس - سورية بدمشق، واستخدام اللغة العربية

ب) اعتماد خطة للانتقال وحذف البيانات بشكل نهائي وغير قابل للاسترداد من بيئة عمل الشريك الاستراتيجي وبما يتفق مع أحكام السرية المصرفية والقوانين النافذة في سورية، وضم المستخدمين الحاليين بصلاحيات إدارة النظام إلى هذه الاتفاقية مع التزام وتعهد شخصي لكل منهم بمضمون هذا الاتفاق.

ج) إعادة هندسة إجراءات العمل على النظام بما ينسجم مع السياسات والإجراءات المعتمدة من مجلس إدارة بنك بيبلوس سورية، مع مراعاة توزع الصلاحيات والبدائل وفق الأسس المعيارية لإدارة قواعد البيانات.

د) منح الصلاحيات على النظام وفق آلية وإجراءات معيارية موثقة ومعتمدة من مجلس إدارة بنك بيبلوس- سورية

هـ) تجميد حسابات المستخدمين من غير العاملين في بنك بيبلوس سورية

و) عدم منح سماحيات الحذف لأي مستخدم على النظام

ز) حصر سماحيات النقل والنسخ والطباعة حسب الحاجة والضرورة

ح) عدم السماح للمستخدمين بالعمل على النظام عن بعد بغض النظر عن الدور الوظيفي

ط) عدم السماح بالعمل على النظام في أيام العطل بغض النظر عن الدور الوظيفي

ي) تطبيق إعدادات على النظام بجدول أيام العمل والعطل (روزنامة) وتحديثها سنوياً.

ك) تطبيق إعدادات على النظام بعدد ساعات العمل حسب القرارات الناظمة من مصرف سورية المركزي

ل) تطبيق هذه المقترحات على كافة مستخدمين النظام

م) ضبط أسماء المستخدمين بما يتطابق مع كافة النظم التقنية المستثمرة في المصرف

ن) تحديث النظام وبيئة التشغيل بشكل دوري حسب مقترحات الموردين

س) وضع إجراءات تشغيل ودعم فني وصيانة ونسخ احتياطي معيارية

رابعاً-نظام CRM System/ Siebel:

تبين بالاطلاع على هذا النظام ووظائفه ومستخدميه الملاحظات التالية:

أ) النظام خارج مركز بيانات بنك بيبلوس - سورية، لدى الشريك الاستراتيجي في بيروت.

ب) وجود مستخدمين من خارج بنك بيبلوس سورية لديهم صلاحيات عالية المستوى Super User لإدارة النظام، ولا يوجد مستخدم بصلاحيات مماثلة في بنك بيبلوس - سورية.

ج) لا يوجد آلية معيارية أو سياسات وإجراءات للعمل معتمدة.

د) عدم استخدام اللغة العربية.

وعليه يوجد قصور ملحوظ في الالتزام بالضوابط ذات الصلة الصادرة عن مجلس النقد والتسليف والممارسات العالمية المثلى، يحمّل المصرف مخاطر مرتفعة متنوعة قد تؤدي إلى آثار جسيمة على المصرف، الأمر الذي يستدعي قيام المصرف بالآتي خلال فترة لا تتجاوز (ثلاثة أشهر) من تاريخ الكتاب:

١. نقل بيئة عمل النظام إلى مركز البيانات الرئيسي في بنك بيبلوس - سورية بدمشق، واستخدام اللغة العربية

٢. اعتماد خطة للانتقال وحذف البيانات بشكل نهائي وغير قابل للاسترداد من بيئة عمل الشريك الاستراتيجي وبما يتفق مع أحكام السرية المصرفية والقوانين السورية النافذة.

٣. منح الصلاحيات على النظام المصرفي وفق آلية وإجراءات معيارية موثقة ومعتمدة من مجلس إدارة بنك بيبلوس - سورية

٤. تجميد حسابات المستخدمين من غير العاملين في بنك بيبلوس- سورية
٥. تطبيق هذه المقترحات على كافة مستخدمين النظام
٦. ضبط أسماء المستخدمين بما يتطابق مع كافة النظم التقنية المستثمرة في المصرف
٧. تحديث النظام وبيئة التشغيل بشكل دوري حسب مقترحات الموردين
٨. وضع إجراءات تشغيل ودعم فني وصيانة ونسخ احتياطي معيارية.

خامساً- نظام مكافحة غسل الأموال وتمويل الإرهاب Fico Tonbeller Compliance Solutions AML

تبين بالاطلاع على هذا النظام ووظائفه ومستخدميه الملاحظات التالية:

أ) النظام خارج مركز بيانات بنك بيبلوس- سورية، لدى الشريك الاستراتيجي في بيروت.
ب) وجود مستخدمين من خارج بنك بيبلوس - سورية لديهم صلاحيات عالية المستوى لإدارة النظام، ولا يوجد مستخدم بصلاحيات مماثلة في بنك بيبلوس - سورية.
ج) لا يوجد آلية معيارية أو سياسات وإجراءات معتمدة للعمل.
د) اختلاف سماحيات المستخدمين من نفس النمط، حيث أن سماحيات ال(ADMINISTRATOR ، Manager (Glob.)، MLRO (Money Laundering Reporting Officer) ، FD (Field Division) Officer) غير ممنوحة كاملةً لجميع الأسماء/المستخدمين الممنوحين هذه السماحيات.
هـ) مستخدم بأكثر من ملف صلاحيات، وتكرار بأسماء المستخدمين
و) عدم استخدام اللغة العربية.

الأمر الذي يستدعي قيام المصرف بالآتي خلال فترة لا تتجاوز (ثلاثة أشهر) من تاريخ الكتاب:

١. نقل بيئة عمل النظام إلى مركز البيانات الرئيسي في بنك بيبلوس - سورية بدمشق، واستخدام اللغة العربية
٢. اعتماد خطة للانتقال وحذف البيانات بشكل نهائي وغير قابل للاسترداد من بيئة عمل الشريك الاستراتيجي وبما يتفق مع أحكام السرية المصرفية والقوانين السورية.
٣. منح الصلاحيات على النظام المصرفي وفق آلية وإجراءات معيارية موثقة ومعتمدة من مجلس إدارة بنك بيبلوس - سورية.
٤. تجميد حسابات المستخدمين من غير العاملين في بنك بيبلوس سورية
٥. تطبيق هذه المقترحات على كافة مستخدمين النظام
٦. ضبط أسماء المستخدمين بما يتطابق مع كافة النظم التقنية المستثمرة في المصرف
٧. تحديث النظام وبيئة التشغيل بشكل دوري حسب مقترحات الموردين
٨. وضع إجراءات تشغيل ودعم فني وصيانة ونسخ احتياطي معيارية.

٤) نتائج متابعة تقارير المهام الرقابية السابقة المنفذة من قبل المفوضية على المصرف:

تبين قصور في الالتزام بأحكام المادة (١) من قرار مجلس النقد والتسليف رقم (٣٩٠/م ن/ب٤) لعام ٢٠٠٨ الخاص بمسؤولية مجلس الإدارة والإدارة العليا في إدارة المخاطر فيما يخص "مسؤولية مجلس الإدارة في إدارة المخاطر" من ناحية عدم اتخاذ ومتابعة كافة الإجراءات التصحيحية المناسبة والكفيلة بتحسين وزيادة فعالية نظام إدارة المخاطر وذلك بناءً على الملاحظات والتوصيات الواردة في تقارير التدقيق الداخلي، وتقارير مراقبي مفوضية الحكومة وفي هذا أيضاً قصور في الالتزام بالمادة (١_و)/٥ من القرار ١٢٠/م ن/ب٤ لجهة عدم معالجة نتائج المهام الرقابية وفق الآتي:

أولاً- المهام المنفذة في عامي ٢٠١٠[٦]-٢٠١٢[٧]: تبين استمرار بعض الملاحظات وفق الآتي:

أ) التأخر في تأمين تزويد مستخدمي الأنظمة بالسماحيات اللازمة لعملهم نتيجة اعتماد المصرف على الإسناد الخارجي في أعمال التقنية حيث أن تزويد مستخدمي الأنظمة لدى المصرف باسم المستخدم وكلمة السر الخاصة بهم على نظام غلوبس يتم من قبل وحدة التقنية لدى بيبلوس- لبنان الأمر الذي يؤدي في كثير من الأحيان لعرقلة العمل كما حال أيضاً دون حصول الفريق الرقابي على سماحية الاستعلام على نظام المصرف والتي تم طلبها بموجب الكتاب رقم ٨/١٠٠/٨٠٨٠٤ تاريخ ٢٠٠٩/١٢/٣ حيث انتهت الأعمال الميدانية للمهمة بتاريخ ٢٠١٠/٢/٢٠ ولم يزود الفريق الرقابي بالسماحية المطلوبة.

ب) عدم الالتزام بالمادة (٧) من القرار ١٠٦ لعام ٢٠٠٥ المتعلق بالمخاطر التشغيلية لجهة عدم اعتماد مجلس إدارة بنك بيبلوس – سورية كافة الوثائق الناظمة للأعمال التقنية: (سياسة أمن المعلومات –إجراءات أمن المعلومات –إجراءات النسخ الاحتياطي- خطة استمرارية العمل)

ج) إن سياسة أمن المعلومات الصادرة في أيار/ ٢٠٠٩ والتي تم تزويد الفريق الرقابي بها تعود لبنك بيبلوس- لبنان ولا يوجد ما يشير إلى إقرار هذه السياسة من قبل مجلس إدارة المصرف- وذلك من واقع محاضر اجتماعات المجلس- كما أن هذه السياسات باللغة الانكليزية.

د) عدم الالتزام ببعض جوانب القرار رقم (٣٩١/م.ن/ب٤) لعام ٢٠٠٨ ناحية أن الموقع البديل في حالات الطوارئ هو بناء الإدارة العامة لبنك بيبلوس – سورية وهو في موقع جغرافي قريب جداً من الموقع الأصلي، بالإضافة إلى أن الموقع البديل في بناء بنك بيبلوس- لبنان لا يمكّن المعنيين بخطة

---

[٥] اتخاذ كافة الإجراءات الآيلة إلى التأكد من أن الإدارة العامة في المصرف قد اتخذت كافة الإجراءات لتصحيح الخلل الذي قد يفصح عنه كل من المفتش الخارجي وقسم التدقيق الداخلي والمراقب الداخلي ومفوضية الحكومة لدى المصارف في المصرف المركزي.

[٦] بموجب الكتاب رقم ٨/١٠٠/٥٢٨٧ وتم مخاطبة المصرف بالملاحظات بالكتاب رقم ١٦٣/٣٥٢٣ تاريخ ٢٠١٠/١١/٠٧، وتم متابعة بعض ملاحظات هذه المهمة بموجب الكتاب رقم ١٦٣/٩٢٢ تاريخ ٢٠١١/٣/١٧.

[٧] بموجب الكتاب رقم (١٦٣/٢٩١) تاريخ ٢٠١٢/٦/٥.

استمرارية العمل من تقديم الخدمات لعملاء المصرف في سورية في حالات الطوارئ عند انقطاع خطوط الاتصالات

هـ) عدم تقيد المصرف بالمادة (٦) من قرار مجلس النقد والتسليف رقم (١٢٠/م.ن/ ب٤) المتعلق بالتعليمات الخاصة بأنظمة الضبط الداخلي الخاصة بالأمان التكنولوجي من عدة نواحي هامة تعكس مخاطر تشغيلية عالية لدى المصرف أهمها: عدم وجود وحدة (هيئة) مسؤولة عن أمان تكنولوجيا المعلومات لدى المصرف أو مسؤول عن أمان تكنولوجيا المعلومات وتتولى وحدة أمن المعلومات (ISU) في مصرف بيبلوس لبنان هذه المهمة.

و) مخالفة قرار مجلس النقد والتسليف رقم ١٢٠/م ن/ب٤ المادة السادسة منه والمتعلقة بالأمان التكنولوجي، ناحية تسليم بنك بيبلوس - لبنان نسخة عن بيانات المصرف عن طريق شركة للنقل، ما ينطوي على هذه الطريقة مخاطر تشغيلية مرتفعة ناتجة عن الطريقة غير الآمنة لنقل البيانات

ز) عدم وجود سجل للحوادث الخاصة بمحاولات أو عمليات اختراق أمن المعلومات إضافة إلى عدم وجود آلية موثقة لقيد حوادث الأمان التي تطال بيئة تكنولوجيا المعلومات وكيفية الإبلاغ عنها للجهة المختصة.

ح) مخالفة البند /١ / من للمادة /٦/ من القرار رقم (١٢٠/م ن/ب ٤) تاريخ ٢٠٠٥/٣/١٥ والذي يتضمن الاحتفاظ بنسخ إضافية للمعلومات المخزنة في أماكن مختلفة، ناحية تنفيذ النسخ الاحتياطي لباقي الأنظمة غير المصرفية (Payroll،..) على نسخة واحدة تحفظ في خزائن أمنية خاصة لدى الإدارة العامة

ط) عدم وجود سجل بالتسليم والاستلام الخاص بالوسائط الممغنطة التي ترحل بشكل يومي إلى مكان آخر غير المصرف، وعدم وجود ضوابط لضمان أن عملية النقل آمنة.

ي) تتم إدارة كافة الأنظمة ومنح السماحيات وتنفيذ بعض عمليات الدعم الفني من خلال العاملين في الوحدة التقنية وقسم أمن المعلومات في بنك بيبلوس – لبنان حصراً، (على الرغم من وجود المخدمات الخاصة بالأنظمة المستثمرة في الإدارة العامة لبنك بيبلوس - سورية ما عدا مخدم السويفت)

ك) ضعف في الصلاحيات الممنوحة للوحدة التقنية في بنك بيبلوس – سورية والتي تعتبر جزء من الوحدة التقنية لبنك بيبلوس- لبنان من حيث الإجراءات الوظيفية، فهي تقوم بالأعمال المطلوبة منها بإشراف وتوجيه كامل من الوحدة التقنية وقسم أمن المعلومات في بنك بيبلوس- لبنان علماً أنه لا يوجد وحدة لأمن المعلومات في بيبلوس – سورية، الأمر الذي ينطوي على مخاطر تشغيلية تتمثل بعدم قدرة الوحدة التقنية في البنك على القيام بالأعمال التي تضمن حسن استمرارية العمل في البنك في حال تعذر تقديم الدعم الفني من قبل الوحدة التقنية وقسم أمن المعلومات في بنك بيبلوس- لبنان

ل) مخالفة قرار مجلس النقد والتسليف رقم (٣٩١/م.ن/ب٤) الخاص بمتطلبات استمرارية العمل الصادر منذ أيار ٢٠٠٨ لجهة عدم وجود خطط طوارئ وخطط عمل بديلة وخطة استمرارية عمل مصادق عليها من قبل مجلس الإدارة تضمن مقدرته على الاستمرار في العمل في حال حدوث أعطال هامة في أجهزة الاتصال أو حصول أضرار جسيمة في البنية المادية لموجودات المصرف، ولجهة عدم قيام المصرف لتاريخ المهمة (٢٠١٠/٣/٣٠) بتوفير موقع بديل لاستمرار العمل وذلك لتلافي المخاطر التي قد تعيق أو توقف العمل في موقع العمل الأول إضافة إلى عدم تأمين العدد الكافي من العاملين للعمل في الموقع أو المواقع البديلة وتدريبهم بشكل مناسب للقيام بأعمالهم

م) يتم تنفيذ بعض العلميات المصرفية من خلال نظام السويفت والعائدة لبنك بيبلوس- سورية من قبل بنك بيبلوس- لبنان (مثل: اعتمادات الاستيراد فوق مبلغ ١٥٠ ٠٠٠ دولار أمريكي – اعتمادات التصدير) الأمر الذي ينعكس سلباً على استقلالية المصرف من جهة وينطوي على مخاطر تشغيلية على البنك تتمثل بعدم قدرة بنك بيبلوس- سورية على تنفيذ بعض الوظائف المصرفية الهامة دون الاعتماد على بنك بيبلوس- لبنان من جهة ثانية، والذي يحول أيضاً دون تطوير الخبرات المصرفية لدى العاملين في بنك بيبلوس- سورية

ن) عدم توقيع مستخدمي الأنظمة على بيان خاص يظهر الصلاحيات المعطاة لهم والمحظورات عليهم عند تزويدهم بالصلاحيات الخاصة باستخدام الأنظمة المعلوماتية.

س) إن الرديف لبعض الأشخاص المفوضين بالعمل على نظام Globus ونظام السويفت في بنك بيبلوس - سورية هو من العاملين في بنك بيبلوس- لبنان، ما ينعكس سلباً على استقلالية المصرف وينطوي على مخاطر تشغيلية على البنك تتمثل بعدم القدرة على استكمال تنفيذ بعض العمليات في حال غياب أحد العاملين لدى بيبلوس - سورية دون الاعتماد على بنك بيبلوس- لبنان

ع) إن مخدمات نظام السويفت موجود جميعها في لبنان، الأمر الذي ينطوي على مخاطر تشغيلية تتمثل بعدم القدرة على تنفيذ أي عمليات على نظام السويفت في حال انقطاع الاتصال مع بنك بيبلوس- لبنان

ف) يتم حفظ عمليات نهاية اليوم لمدة خمسة أيام على نفس السيرفر (المخدم) الذي يتم استخدامه لطباعة وإنشاء التقارير وبالتالي فإن لدى جميع المستخدمين المخولين بالدخول على النظام إمكانية الدخول إلى النظام الرئيسي في المصرف والاطلاع على بيانات المصرف المالية (ميزانية – قائمة دخل- وغير ذلك).

ص) شبكة الاتصال الحاسوبية لدى المصرف هي جزء من شبكة الاتصال الخاصة بمجموعة بنك بيبلوس وتنحصر إدارة الشبكة الحاسوبية في الوحدة التقنية وقسم أمن المعلومات لدى بنك بيبلوس- لبنان، الأمر الذي ينطوي على مخاطر تشغيلية على البنك تتمثل بعدم قدرة بنك بيبلوس- سورية بتنفيذ جميع عمليات الإدارة للشبكة (مثل: تعريف مستثمر جديد، تطوير وتوسيع

شبكة الاتصال، ضوابط أمن المعلومات المتعلقة بالشبكة .....) وبعض عمليات الدعم الفني في حال تعذر الحصول على الدعم الفني من بنك بيبلوس- لبنان

ق) وجود خلل في النظام المصرفي (Globus) يمكّن بعض العاملين من الاطلاع على بعض البيانات غير المخولين بالاطلاع عليها (تقارير القوائم المالية لنهاية اليوم – حسابات العملاء)، الأمر الذي يؤثر سلباً على السرية المصرفية لعملاء البنك.

ر) لم يتم اتخاذ الإجراءات اللازمة بخصوص النتائج المنبثقة عن مهمة التدقيق المعلوماتي المنفذة بالكتاب رقم (١٦٣/٢٩١) تاريخ ٢٠١٢/٦/٥ وفق الآتي:

١. العمل على تصحيح الخلل المكتشف على النظام المصرفي (Globus) بالسرعة الممكنة وتزويدنا بالوثائق ذات الصلة.

٢. العمل على إعداد كافة الوثائق الناظمة للأعمال التقنية[٨]: (وثيقة أمن المعلومات – وثيقة إجراءات أمن المعلومات – وثيقة النسخ الاحتياطي- خطة استمرارية العمل) باللغة العربية واعتمادها من قبل مجلس إدارة بنك بيبلوس – سورية.

٣. العمل على تطوير واعتماد خطة استمرارية عمل خاصة ببنك بيبلوس – سورية[٩] بحيث: (تحقق خطة استمرارية العمل جميع المتطلبات الواردة في قرار مجلس النقد والتسليف رقم (٣٩١/م.ن/ب٤) لعام ٢٠٠٨.

٤. أن تكون باللغة العربية- أن يتم اعتمادها من قبل مجلس إدارة بنك بيبلوس – سورية- أن يتم اختبارها وتحديثها بشكل دوري)

٥. تحديث وثيقة إجراءات النسخ الاحتياطي بحيث تراعي حفظ نسخة واحدة على الأقل من النسخ الاحتياطي خارج مبنى الإدارة العامة للبنك في سورية[١٠].

٦. العمل على الحد من الاعتماد الكبير على الشريك الاستراتيجي في المهام التقنية للحد من المخاطر التشغيلية المترتبة على هذا الاعتماد من خلال توفير الكادر التقني المؤهل والقادر على القيام بكافة مهام إدارة الأنظمة والدعم الفني وإدارة الشبكة الحاسوبية وأي مهام أخرى يقوم بها حالياً الشريك الاستراتيجي، وأن يقتصر دور الشريك الاستراتيجي على القيام بعمليات الإشراف والمتابعة والدعم الفني في حالات الضرورة فقط، دون أن ينفرد بالقيام بمهام

---

[٨] معظم الأدلة التي تم الاطلاع عليها في سياق المهمة الرقابية الحالية هي لمجموعة بنك بيبلوس

[٩] تم الاطلاع على خطط استمرارية العمل باللغة الإنكليزية للأقسام التالية: الإدارية، التجارية، الاستثمارية، القانونية، الخدمات (عمليات- مدفوعات- تحويلات- إدارة مخاطر- عمليات تجارية- بطاقات)، الخزينة؛ حيث معظم الوثائق بإصدار عام ٢٠١٦، وموقعة من قبل رئيس القسم ورئيس الدائرة في عام ٢٠١٧. كما لم يجري عليها تحديث أو اختبار. ولا يوجد خطة استمرارية خاصة بتقانة المعلومات وفق قرار مجلس النقد والتسليف رقم ٣٩١ لعام ٢٠٠٨

[١٠] يتوفر إجرائية عمل ولكنها غير مكتوبة أو موثقة

محددة، وكذلك إنشاء وحدة خاصة بأمن المعلومات في بنك بيبلوس سورية للقيام بالمهام التي يقوم بها حالياً قسم أمن المعلومات لدى بنك بيبلوس– لبنان[١١].

٧. بالنسبة للمخدمات العائدة للأنظمة المستثمرة : الاحتفاظ بنسخة احتياطية يومية عن عمليات نظام السويفت الخاص ببنك بيبلوس - سورية، نظراً لصعوبة تشغيل نظام السويفت من خلال مخدم خاص موجود داخل الأراضي السورية، والاستفادة من البيئة الخاصة بمخدم نظام التواقيع (VM Server) لإنشاء مخدمات احتياطية (Backup Servers) للأنظمة الأخرى التي ليس لها مخدم احتياطي[١٢].

٨. بالنسبة للشبكة الحاسوبية (Domain Network) : أن يكون لدى بنك بيبلوس – سورية نطاق عمل للشبكة الحاسوبية (Domain Network) مستقل عن النطاق الخاص بالشريك الاستراتيجي، وأن يقتصر دور الشريك الاستراتيجي على تقديم الدعم الفني في حالات الضرورة فقط، دون أن ينفرد بالقيام بمهام محددة والتنسيق المشترك في كل ما يتعلق بالأعمال المشتركة[١٣].

ثانياً- المهام المنفذة من قبل التدقيق الداخلي وفي ذلك قصور بالالتزام بالمادة (٣)[١٤] من القرار ١٢١/م ن/ب٤ لجهة الآتي:

بالنسبة لتقارير التدقيق الداخلي المتعلقة بتدقيق نظم المعلومات المنفذة من قبل الشريك الاستراتيجي فإن هذه التقارير لا ترسل إلى بنك بيبلوس - سورية باعتبار أن المعني الفعلي بالأمور التقنية هو الوحدة التقنية لدى الشريك الاستراتيجي، الأمر الذي يعتبر غير مقبول فلا بد من إرسال نسخة عن التقارير إلى المصرف ليصار لاتخاذ اللازم لمعالجة جوانب القصور التي قد تكون متضمنة في التقارير، مع أهمية اتخاذ المصرف الإجراءات اللازمة لتفعيل دور التدقيق الداخلي في المصرف للقيام بالمهام المناطة به وعدم الاستمرار في الاعتماد على الشريك الاستراتيجي بهذا الخصوص، والجداول التالية تتضمن متابعة تقارير مهام التدقيق الداخلي المنفذة والرأي الرقابي للفريق:

جدول رقم (٤):متابعة تقرير المهمة الرقابية المنفذة من قبل التدقيق الداخلي رقم ٢٠١٧/١٢٠

التقرير رقم: BBS-IT-٠١٦-١٦١٢٠ - ، تاريخ: ٢٠١٧/٠٢/٢٤	مخاطر عالية :ع

[١١] الكادر التقني الحالي في المصرف هو شخصين، وبشكل فعلي شخص واحد، ويعتمد المصرف كلياً على بنك بيبلوس- لبنان

[١٢] لا يوجد نظام سويفت خاص ببنك بيبلوس-سورية، المستخدم هو نظام سويفت لمجموعة بنك بيبلوس في لبنان.

[١٣] يقوم بنك بيبلوس-لبنان بكافة المهام التشغيلية والإدارية والدعم الفني والصيانة سواء كانت مباشرة أو من خلال طرف خارجي

[١٤] على مجلس إدارة المصرف أن يقوم دورياً بتقييم إنجازه والتعرف على الصعوبات التي تواجهه والخلل الذي يؤثّر على هذا الإنجاز، هذا الأمر يتطلب الاجتماع دورياً مع الإدارة العامة، وأفراد التدقيق الداخلي في المصرف والتعرف منهم على مدى التقيد بالقوانين والتعليمات والسياسات المفروضة واستعراض الصعوبات والمشاكل التي تواجه المصرف.

		مخاطر متوسطة :م مخاطر منخفضة :خ		
نطاق التقرير: System Debit Cards Management - BBS - ضوابط أمن المعلومات - فعالية وكفاءة إجراءات التسوية والمطابقة - الخطط المطبقة لاستمرارية العمل والاستعادة بعد الطوارئ				
الملاحظة	**الخطورة**	**رد المصرف**	**التقييم**	**ملاحظات الفريق الرقابي**
كلمات مرور المستخدمين مألوفة، ويمكن الدخول من خلال برتوكول FTP إلى مستوى نظام التشغيل UNIX	ع	سوف يتم إلغاء تفعيل مدير نظام Open٢ عندما لا تكون مطلوبة، وسوف يتم تغيير كلمات مرور المستخدمين الآخرين، وذلك قبل نهاية شهر كانون الثاني ٢٠١٧	غير ملتزم	من الأفضل على المصرف الأخذ بالتوصيات المقترحة، وما اتخذه من إجراءات لا يلغي الخطر المحدد
يوجد خطأ في تنسيق رقم الهاتف لبطاقات الخصم	ع	١) طالما أن نقاط البيع (POS) غير متوفرة في سورية، فإن خطورة ذلك منخفضة، كما أنها خدمة عالية التكاليف، لذلك قررت الإدارة تعطيل خدمة الرسائل القصيرة في الوقت الحالي. ٢) سوف يتم في الربع الثاني من عام ٢٠١٧ اتخاذ ما يلزم للحد من إدخال القيم الفارغة أو أرقام بتنسيق خاطئ في حقول رقم الهاتف	ملتزم جزئياً	التوصيات المقترحة أفضل من الإجراءات المقترحة من المصرف، ولا يراعي المصرف كما التقرير الضوابط المعتمدة من مصرف سورية المركزي
سياسة كلمات المرور في نظام Open٢ ضعيفة	ع	سوف يتم تطبيق التوصيات، وسوف تستمر الصعوبات كما في	ملتزم	

		لبنان		
خطة التدقيق المخصصة على مستوى قاعدة لبيانات غير مطبقة	م	سوف يتم إجراء التدقيق على مستوى قاعدة البيانات قبل نهاية الشهر، وتحديد ما سوف يتم تدقيقه من قبل قسم أمن المعلومات قبل نهاية الربع الأول.	غير ملتزم	إجابة المصرف غير واضحة
خطة التدقيق المخصصة على مستوى التطبيق (البرنامج) غير كاملة	م	١) تم إعلام الرقابة الداخلية، لا يوجد نشاطات مسجلة على مستوى البرنامج (محاولات دخول/ تغيير كلمات مرور). ٢) بالنسبة لنظام CAMS يتم تسجيل نشاطات المستخدمين على النظام المطور من قبل شركة كوانتيك. ٣) لا يشمل نشاط قسم أمن المعلومات على ملفات المستخدمين نظراً لارتباطها بأرقام حسابات الزبائن، وسوف يتم التحقق من المورد عن إمكانية تنفيذ التوصيات	غير ملتزم	إجابة المصرف غير واضحة[١٥]
سياسة كلمات المرور لقاعدة البيانات ضعيفة	م	تم إنشاء سياسة كلمة المرور وربطها مع ملف Profile بيبلوس، يوجد ملفين على مستوى قاعدة البيانات: ١) ملف افتراضي: مخططات التطبيق (البرنامج/الإعدادات) ترتبط بهذا الملف، لذلك لا تنتهي فعالية كلمات المرور. ٢) ملف بيبلوس: كافة	غير ملتزم	إجابة المصرف غير واضحة وغير كافية

[١٥] تم مناقشة غالبية ملاحظات المفوضية والمراقبين الداخليين السابقة مع السادة: "المدير العام ونائبه وضابط الارتباط" ضمن الاجتماع الختامي للمهمة بتاريخ ٢٠١٨/١٠/٢٢، وبين السيد نائب المدير العام بأنه سوف يتم الرد رسمياً عند مخاطبة المصرف بنتائج التقرير.

		المستخدمين (وكذلك مدراء قاعدة البيانات) ترتبط بهذا الملف، لذلك تنتهي فعالية كلمة المرور كل ستة أشهر.		
عدم تحصيل الرسوم السنوية لبطاقة الخصم	م	١) يتم استثناء عدد من الحسابات، ويتم التحقق بشكل يومي من خصم الرسوم من حسابات جميع حاملي البطاقات. ٢) طلب السيد نورس سمور من قسم التقانة في بنك بيبلوس المساعدة في دراسة إمكانية أتمتة إجراء تحصيل رسوم بطاقة الخصم السنوية، ولم ترد إجابة على طلبه.	غير ملتزم	إجابة المصرف غير واضحة وغير كافية
المطابقة اليومية بين نظام المصرف T٢٤ ونظام شركة / تتم يدوياً	م	تتم عملية التسوية والمطابقة بين نظام المصرف T٢٤ ونظام شركة CSC منذ عام ٢٠٠٨ بشكل دقيق وفعال، حيث تتم إجراءات المطابقة وفق ضوابط محاسبية دقيقة، ونقترح خفض مستوى الخطورة إلى منخفض بدلاً من متوسط، وسوف يتم أتمتة إجراءات المطابقة بالتنسيق مع قسم التقانة في بيبلوس لبنان خلال الربع الأول من عام ٢٠١٧	غير ملتزم	إجابة المصرف غير واضحة وغير كافية
عمولات العمليات المالية وغير المالية / عمولات CSC منخفضة	م	١) الطريقة الوحيدة لتجميع العمولات المحصلة هي خلال سجل اليومية الإلكتروني ejournal، ولكنه غير مقروء، وسوف يتم التنسيق مع بنك بيبلوس لبنان لإيجاد حل.	غير ملتزم	إجابة المصرف غير واضحة وغير كافية

		٢) بالنسبة لعمولات العمليات المالية المنفذة من قبل عملاء بنك بيبلوس على الصرافات الآلية غير العائدة لبيبلوس، فإننا نقترح تحصيلها من خلال قسم تسوية البطاقات. نعتقد أن ذلك غير مجدي لأن مصدر البيانات المتوفرة لدينا هو شركة CSC. ٣) تحصيل رسوم العمليات غير المالية على حسابات العملاء، الموافقة عليها ماتزال معلقة لدى قسم التقانة في بيبلوس.		
تحديثات وتصحيحات نظام ORACLE غير منفذة	خ	سوف يتم الانتقال إلى نسخة Oracle ١١g خلال عام ٢٠١٧. ومع ذلك فإن تنفيذ التحديثات والتصحيحات من غير ترخيص المورد تعتبر مخاطرة، ونقترح إجراء اختبارات شاملة وتفصيلية على مستوى التطبيق (البرنامج) التي لا نمتلك كفاءة القيام بها.	ملتزم جزئياً	يجب الأخذ بالتوصيات المقترحة
يوجد استثناءات على حسابات بطاقات الخصم/ يمكن تنفيذ عمليات على حسابات من تفويض	خ	يوجد ضوابط في نظام CAMS مرتبطة ببطاقات الخصم فقط للفئات المعتمدة، يمكن تجاوز المشكلة، ونعتقد أن القائمة المبينة تتعلق بمشاكل نظم قديمة.	ملتزم جزئياً	يجب الأخذ بالتوصيات المقترحة، بغض النظر عن مستوى الخطورة غير المقبول/ هذه الملاحظة من مستوى خطورة عالي
يوجد بطاقات فعالة لحسابات مغلقة	خ	١) طالما أن مخاطر هذه الملاحظة معدومة ويتم التحكم بتجديد البطاقات شهرياً، لذلك فإن	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، بغض النظر عن

		كافة الحسابات المغلقة المرتبطة بها سوف تلغى على التوالي. في معظم الأحيان يتم إرسال بريد إلكتروني للفروع من أجل الانتباه والاهتمام بالتنبيهات الصادرة عن نظام T٢٤ عندما يقوم قسم الخدمات المصرفية بإغلاق حساب مرتبط ببطاقة خصم. ٢) بالنسبة للبطاقات الإضافية، سوف نتأكد من إلغائها فور إلغاء البطاقة الرئيسية وسوف يتم تطبيق الضوابط اللازمة. يجب أن تتم مراجعة إجراءات بطاقات الخصم، البطاقات الإضافية المرتبطة للحسابات المشتركة و/أو يجب أن تبقى فعالة إذا تم دفع الرسوم مسبقاً حتى إذا تم إلغاء البطاقة الرئيسية لدى العميل الحق بتعليقها حتى انتهاء الصلاحية، كلا العميلان يجب أن يتم معاملتهم رئيسيان.		مستوى الخطورة غير المقبول/ هذه الملاحظة من مستوى خطورة عالي
لا يوجد تقارير لتحليل ربحية بطاقات الخصم وأجهزة الصراف الآلية	خ	لم يتم إعداد تقارير تحليل الربحية بسبب عدم دقة النتائج والتغيرات المرتفعة لمعدلات سعر صرف الدولار مقابل الليرة السورية	ملتزم جزئياً	

جدول رقم (٥):متابعة تقرير المهمة الرقابية المنفذة من قبل التدقيق الداخلي رقم ٢٠١٧/٩٤

التقرير رقم: ٠٩٤- BBS-IT- ١٧-٠١٣، تاريخ: ٢٠١٧/٠٧/١٧	مخاطر عالية :ع مخاطر متوسطة :م

Program٢٤T نطاق التقرير: Change Control - BBS - السياسات والإجراءات - إجراء التغييرات واختبارها وتوثيقها واعتمادها من المستخدمين النهائيين بشكل صحيح - التأكد من الفصل بين المهام في ضوابط عملية التغيير ٢٤ T- التأكد من سلامة وموثوقية بيئة أثناء إجراء التغييرات	مخاطر منخفضة :خ	

رت	الملاحظة	الخطورة	رد المصرف	التقييم	ملاحظات الفريق الرقابي
١	أمن مكتبات الموجهات الفرعية غير جيدة	ع	سوف يتم إيقاف بروتوكول FTP لجميع المستخدمين، وسوف يتم تطبيق Build.Control خلال الربع الأول من ٢٠١٨	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة
٢	الكود المصدري لنظام T٢٤ متاح في بيئة الإنتاج (الاستثمار)	ع	سوف يتم اعتماد Build.Control خلال الربع الأول من ٢٠١٨، وبالنسبة إلى الموجه STAT.LINE.MVMT.ALL.KEY فإنه مرتبطة بعدد كبير من الملفات الموزعة. تم تطويره واختباره على نسخة قيد التشغيل.	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة
٣	لا يوجد بيئة تشغيل تجريبية	ع	مع تطبيق Build.Control عملية الانتقال إلى وضع التشغيل سو تعدل لتكون	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام

	لنظام T٢٤ ولا مدير تقني		على بيئة تجريبية للتشغيل (Pre-Live) مع دور لمدير التقانة. قبل ذلك لا يمكننا فعل أي شيء على بيئة التشغيل التي تشمل حالياً الكود المصدري.		بالقرارات فيما يخص نطاق المهمة
٤	لا يوجد ملف لحفظ وصف التغييرات DL.DEFINE	م	١) تطوير التوجهات وتعديل توزيع الأهداف (بشكل أساسي تنتهي مع ALL.KEY)، مثلاً التوجيه للإنشاء والتعديل والاختبار على نسخة تشغيلية. ٢) يتم استلام توجهات من مكتب الدعم الفني لشركة Temenous لحل المشاكل المسجلة لديهم..	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة
٥	لا يتم تحديث حالات مدير الخدمة	خ	١) التغيير C٢٩٧٦٩ متعلق بنظام T٢٤ سورية وتم تصحيحه ٢) التغيير C٢٥٨٩٥ متعلق بنظام T٢٤ سورية وتم تصحيحه ٣) التغيير C٢٤٧٩٢ متعلق بنظام T٢٤ سورية، ولا يحتاج إلى تصحيح ٤) بالنسبة لقائمة التغييرات المعلقة، يجب إعادة التحقق منها من قبل المدقق، ويجب أن يتم حل هذه القضية	ملتزم جزئياً	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة

٦	وثائق موجهات إجرائيات معالجة) T٢٤	خ	نؤيد توصيات المدقق وملاحظاته وننتظر فريق التطوير للقيام بها. وبكافة الأحوال هي من مستوى مخاطر منخفض (تمت مخاطبة بنك بيبلوس لبنان من أجل تطوير ٢٤٠٠ عملية خلال السنوات الماضية). وأكثر من ذلك تمت مشاركة التدقيق المعلوماتي مؤخراً وإعداد توثيق نموذجي في نظام T٢٤ /بنك بيبلوس لبنان، وسوف تستخدم للموردين خلال عملية التحديث.	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة
٧	يجب تحديث إجراء إدارة التغيير الخاص بنظام T٢٤	خ	تم إرسال الطلب مسبقاً إلى OSP	غير ملتزم	يجب الأخذ بالتوصيات المقترحة، وإعادة التقييم في مهام لاحقة والالتزام بالقرارات فيما يخص نطاق المهمة